Monitoring & Logging Policy

Date	Version	Author	Description	Approved By	Last Updated	Review Frequency	Next Review

Purpose

This policy ensures that Stark Industries Inc. effectively monitors its information systems to detect, investigate, and respond to unauthorised or abnormal activities while maintaining the integrity and confidentiality of logs. This policy is aligned with ISO/IEC 27001:2022 (A.8.15 - A.8.17).

Scope

Applies to all cloud environments (e.g. AWS), internal systems, endpoints, applications (e.g. SaaS platform, admin tools), and development infrastructure (e.g. GitHub Actions, CI/CD pipelines) under Stark Industries Inc.'s ISMS scope.

Objectives

- Detect security incidents and policy violations in real time
- Preserve forensic evidence through log retention and protection
- Meet audit, regulatory, and contractual logging requirements

Logging Requirements (A.8.15)

Stark Industries must log the following events:

Event Type	Examples
Authentication events	Successful and failed login attempts, MFA bypass
System changes	User provisioning, permissions changes, deployments
Network activity	Firewall changes, VPN connections, AWS Security Group changes
Application events	Code pushes, build failures, admin access to production
Incident indicators	Anomalous behaviour, alerts from IDS/WAF, brute force attempts

Retention and Storage (A.8.16)

- Logs are retained for a **minimum of 12 months**
- Stored in a secure, centralised log management system (e.g. AWS CloudWatch, SIEM)
- Backups of critical logs are encrypted and stored separately

Protection and Integrity

- Logs are protected against tampering using:
  - Role-based access control (RBAC)
  - Immutable storage features (e.g. AWS S3 object lock)
- Only authorised personnel may access logs
- Logs must not be modified or deleted without documented approval

Review and Monitoring

- **Daily automated log reviews** for key systems and security events
- Alerts are generated for:
  - Failed login attempts
  - Access to sensitive data
  - Unusual network traffic
  - Deployment outside approved hours

Real-Time Monitoring (A.8.17)

- Continuous monitoring is performed for:
  - SaaS application health
  - Cloud infrastructure changes
  - IAM role misuse or privilege escalation
- Alerts are triaged by the **Information Security Analyst**
- Critical alerts are escalated to the **Information Security Manager** within 1 hour

Integration with Incident Management

- All log events that indicate suspicious activity are escalated per the **Incident Management Policy**
- Logs serve as evidence for internal investigation and post-incident review

Roles and Responsibilities

Role	Responsibility
Information Security Analyst	Triage alerts, conduct regular log reviews
Infrastructure Engineer	Ensure logging agents are deployed and functioning
GRC Analyst	Verify log retention and review compliance
IS Manager	Oversee monitoring policy, update procedures, and approve exceptions

Compliance and Auditing

- Logging is auditable and aligned with:
  - ISO 27001
  - Customer SLAs and due diligence requirements
- Quarterly internal audits are conducted on:
  - Log integrity
  - Review completeness
  - Alerting thresholds

Exceptions

Any exceptions to this policy must be:

- Documented with a valid justification
- Reviewed and approved by the Information Security Manager

Policy Review

- This policy is reviewed **annually** or upon significant change to the environment or regulatory requirements.